Atividade Prática M1 – Engenharia de Software

Controle de acesso, gestão de pedidos e auditoria

ATIVIDADE PRÁTICA INDIVIDUAL

Tecnologias do projeto: Java , Spring Boot, Spring Security, MongoDB e Thymeleaf.

1. Contextualização e objetivo

Uma pizzaria utiliza o sistema PediuPatrão para cadastrar clientes, gerenciar produtos e registrar pedidos. Entretanto, o crescimento do estabelecimento trouxe a necessidade de diferenciar as responsabilidades dos funcionários, controlar a entrada e a saída dos pedidos e identificar as alterações realizadas nas informações comerciais e cadastrais.

Você deverá evoluir individualmente o projeto fornecido, aproveitando sua arquitetura e suas tecnologias, preservando as funcionalidades existentes e desenvolvendo as regras de negócio, os mecanismos de autorização e o registro de auditoria descritos neste enunciado.

2. Situação inicial do projeto

O projeto disponibilizado possui organização em camadas, com entidades, repositórios, serviços e controladores, autenticação com Spring Security e persistência no MongoDB. A atividade parte das seguintes lacunas identificadas:

Componente	Situação inicial
Usuários	Perfis ADMIN e USER; a autenticação atribui a role USER aos usuários autenticados.
Pedidos	Criação, listagem e atualização de status sem transições suficientemente controladas.
Clientes	Cadastro, consulta, alteração e exclusão.
Descontos	Funcionalidade não implementada.
Entrada e saída	Sem controle específico de horários e transições.
Auditoria	Não implementada.
Autorização	Sem diferenciação efetiva por perfil; revisar proteção das APIs e tratamento de CSRF.

3. Requisitos funcionais

RF01 — Controle de usuários e permissões (2,0 pontos)

Adequar o cadastro, a autenticação e a autorização para três perfis de acesso:

Perfil	Responsabilidades
ADMIN	Administrar usuários, atribuir perfis, consultar pedidos e visualizar a auditoria.
GERENTE	Gerenciar pedidos, aplicar descontos, cancelar pedidos, consultar clientes e visualizar a auditoria.
ATENDENTE	Cadastrar e atualizar clientes, registrar pedidos e acompanhar seu andamento.

Somente o GERENTE poderá aplicar descontos ou cancelar pedidos, inclusive quando comparado ao ADMIN. A proteção deve ser aplicada no backend por meio do Spring Security; ocultar botões não é suficiente. Restringir o cadastro e a alteração de perfis para impedir a atribuição indevida de privilégios.

RF02 — Evolução do cadastro de pedidos (1,0 ponto)

Complementar a entidade Pedido e as operações correspondentes para registrar itens, quantidades, preços, descontos, valor total, responsável pelo registro e data/hora de entrada. O valor final deve ser calculado no servidor com base nos itens e nos descontos autorizados; requisições HTTP não poderão definir arbitrariamente esse total.

RF03 — Controle de entrada, saída e transições dos pedidos (1,5 ponto)

Implementar e validar o fluxo obrigatório de pedidos:

1. RECEBIDO — registrar data/hora de entrada e usuário responsável.
2. EM PREPARAÇÃO — pedido encaminhado à cozinha.
3. PRONTO — aguardando retirada ou entrega.
4. SAIU PARA ENTREGA / RETIRADO — registrar obrigatoriamente data/hora e responsável pela saída.
5. FINALIZADO — atendimento concluído.

CANCELADO é um estado excepcional, permitido apenas ao GERENTE enquanto o pedido não tiver saído para entrega ou retirada. O cancelamento exige justificativa e auditoria. Impedir transições inválidas (por exemplo, finalizar um pedido em preparação), bem como qualquer alteração de status após o cancelamento.

RF04 — Cancelamentos e descontos (1,5 ponto)

Desenvolver operações exclusivas do GERENTE para cancelar pedidos e aplicar descontos. O cancelamento exige justificativa, preserva os dados históricos e impede alterações posteriores. O desconto será percentual, limitado a 20% do valor do pedido, e somente poderá ocorrer antes da saída para entrega ou retirada. Registrar ambas as operações na auditoria, incluindo usuário, data/hora e dados anteriores e posteriores pertinentes.

RF05 — Auditoria das alterações de pedidos e clientes (3,0 pontos)

Implementar mecanismo de auditoria persistente no MongoDB. Devem ser auditadas inclusões e alterações de pedidos, mudanças de status, descontos, cancelamentos e alterações dos dados de clientes, especialmente endereços e telefones. Cada evento deverá registrar:

- Identificação do usuário autenticado e seu perfil;
- Data e hora da operação;
- Tipo de operação e entidade afetada, incluindo seu identificador;
- Campos modificados e respectivos valores anteriores e novos;
- Justificativa, quando exigida pela regra de negócio.

Disponibilizar consulta aos registros de auditoria exclusivamente para ADMIN e GERENTE. Não permitir alteração ou exclusão dos registros pelas interfaces ou APIs comuns. Não registrar senhas, tokens ou outras credenciais em logs. Quando aplicável, restringir a exposição de dados pessoais de acordo com a finalidade da auditoria.

Exemplo de registro de auditoria:

Campo	Exemplo
Usuário	atendente01
Operação	ALTERAÇÃO DE CLIENTE
Campo alterado	logradouro
Valor anterior	Rua das Flores
Novo valor	Av. Brasil
Data e hora	23/09/2026 — 14:35

4. Requisitos técnicos e critérios de implementação

- Manter Java, Spring Boot, Spring Security, Thymeleaf e MongoDB, aproveitando as camadas existentes do projeto.
- Implementar as regras de negócio na camada de serviços e a autorização no backend; não depender somente de validação no navegador.
- Revisar SecurityConfig, UsuarioDetailsService, Pedido, PedidoService, ClienteService e os controladores e formulários correspondentes.
- Criar entidade, repositório e serviço próprios para auditoria.
- Revisar a segurança das rotas de cadastro e gestão de usuários e o tratamento de CSRF em formulários e operações sensíveis.
- Manter código organizado, com nomenclatura consistente e tratamento apropriado de erros e tentativas de acesso indevido.

5. Avaliação — distribuição por complexidade

A pontuação máxima é 10,0 pontos. Auditoria e controle de acesso têm maior peso por envolverem autenticação, regras de negócio, persistência e segurança.

Critério	Pontos
RF01 — Controle de usuários e permissões	2,0
RF02 — Evolução do cadastro de pedidos	1,0
RF03 — Controle de entrada, saída e transições	1,5
RF04 — Cancelamentos e descontos exclusivos do gerente	1,5
RF05 — Auditoria de pedidos e clientes	3,0
Qualidade do código, testes e demonstração individual	1,0
TOTAL	10,0

Detalhamento da pontuação:

Item	Evidência exigida	Pontos
RF01	Três perfis implementados e corretamente atribuídos	0,7
RF01	Autorização efetiva no backend e proteção das APIs	0,9
RF01	Administração segura dos perfis e proteção contra autoelevação	0,4
RF02	Modelo do pedido, itens, quantidades, responsável e entrada	0,5
RF02	Cálculo de valores no servidor e validações	0,5
RF03	Estados e transições válidas, com bloqueios	0,9

RF03	Registros de entrada, saída e responsáveis	0,6
RF04	Cancelamento restrito, com justificativa e bloqueios	0,8
RF04	Desconto restrito ao gerente, limitado e validado	0,7
RF05	Auditoria persistente das mudanças de pedidos	1,0
RF05	Auditoria das alterações cadastrais de clientes	0,8
RF05	Identificação, data/hora e valores anteriores/novos	0,7
RF05	Consulta restrita, integridade e proteção de dados	0,5
Qualidade	Organização, tratamento de erros e testes	0,5
Qualidade	README e demonstração individual em vídeo	0,5

A atribuição dos pontos será proporcional à implementação funcional demonstrada e verificável no código. Interfaces visuais que não possuam a regra correspondente no backend não atendem aos requisitos de autorização.

6. Entrega individual

Cada aluno deverá entregar o projeto completo em repositório GitHub individual, acompanhado de README com instruções de execução, requisitos implementados e descrição das principais alterações realizadas.

É obrigatório apresentar vídeo curto gravado diretamente da tela demonstrando: autenticação dos três perfis; bloqueio de operações não autorizadas; entrada, transições e saída de pedidos; cancelamento e desconto pelo GERENTE; alteração de dados de cliente; e consulta aos registros de auditoria resultantes. O vídeo deve permitir identificar claramente a execução das funcionalidades desenvolvidas pelo aluno.

7. Condição de validação

A ocultação de botões conforme o perfil não comprova a aplicação das permissões. O aluno deverá demonstrar que as restrições estão implementadas no backend, inclusive por tentativas de acesso não autorizado às APIs. Os registros de auditoria deverão corresponder às operações executadas durante a demonstração. Entregas com similaridade ao projeto do colega acima de 30% serão desconsideradas e a nota zerada!